

WEB APPLICATION RECONNAISSANCE REPORT

Operation Web Recon

Report ID: **WR-001**

Target: **http://192.168.56.101/DVWA**

Date: **18 June 2026**

Analyst: **Shaik Rida**

1. EXECUTIVE SUMMARY

Reconnaissance conducted against DVWA v1.10 identified multiple exposed information disclosure endpoints, and injection parameters.

Findings include:

- multiple exposed directories.
- fully fingerprinted technology stack.
- confirmed injectable parameters.
- robots.txt file that maps sensitive paths.

2. TECHNOLOGIES IDENTIFIED

Technology	Version
Apache	2.4.68
PHP	8.4
OS	Debian Linux
Database	MariaDB
DVWA	v1.10



Fig 1: kali desktop

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def  
ault qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g  
roup default qlen 1000  
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixro  
ute eth0  
        valid_lft 475sec preferred_lft 475sec  
    inet6 fe80::b8ec:c571:ab30:59db/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever
```

Fig 2: ip address

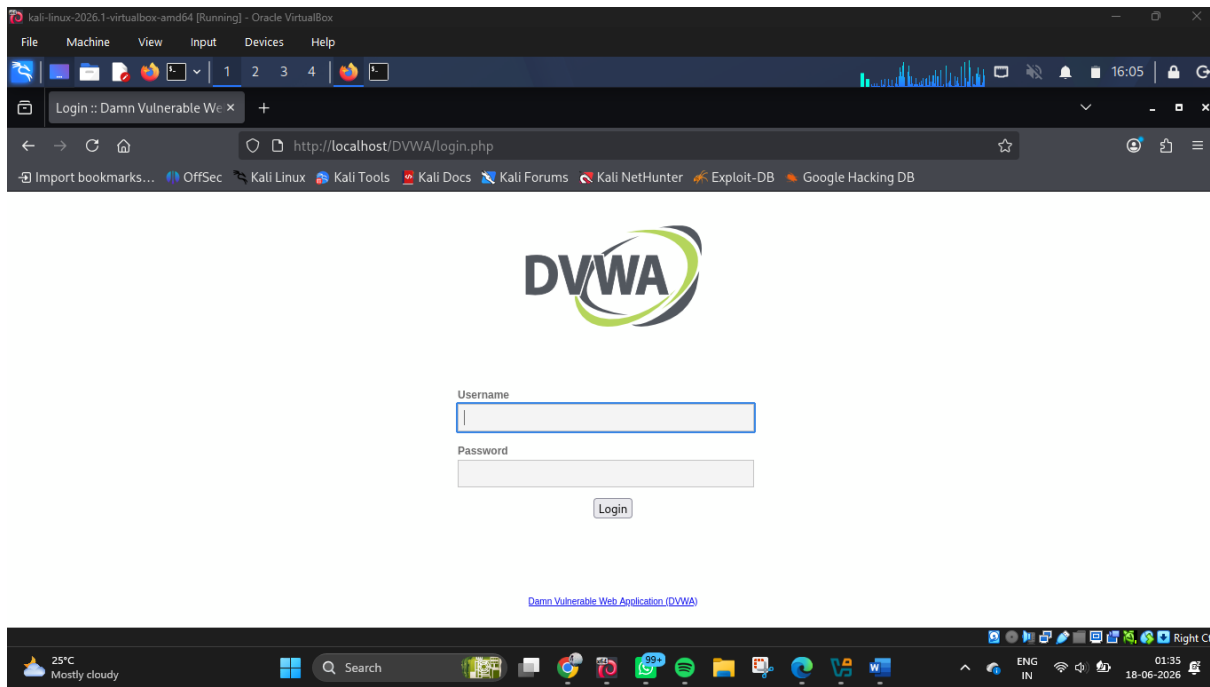


Fig 3: dvwa login page

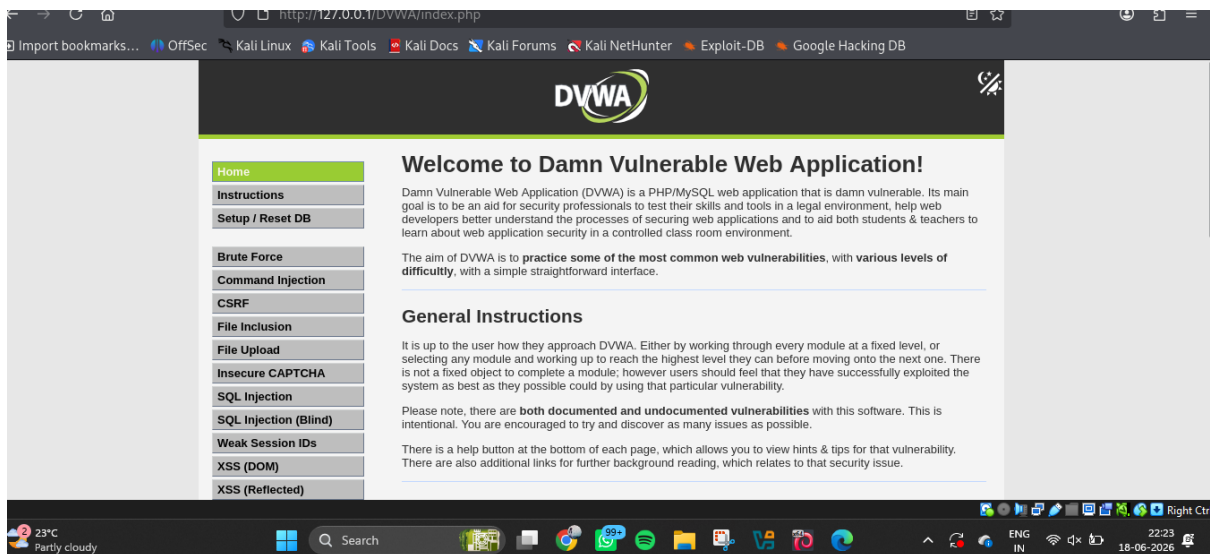


Fig 4: dvwa home page

```

(kali㉿kali)-[~]
└─$ whatweb http://127.0.0.1/DVWA
http://127.0.0.1/DVWA [301 Moved Permanently] Apache[2.4.68], Country[RESERVED][ZZ], HTTPServer[Debian Linux][Apache/2.4.68 (Debian)], IP[127.0.0.1], RedirectLocation[http://127.0.0.1/DVWA/], Title[301 Moved Permanently]
http://127.0.0.1/DVWA/ [302 Found] Apache[2.4.68], Cookies[PHPSESSID,security], Country[RESERVED][ZZ], HTTPServer[Debian Linux][Apache/2.4.68 (Debian)], HttpOnly[PHPSESSID,security], IP[127.0.0.1], RedirectLocation[login.php]
http://127.0.0.1/DVWA/login.php [200 OK] Apache[2.4.68], Country[RESERVED][ZZ], DVWA, HTML5, HTTPServer[Debian Linux][Apache/2.4.68 (Debian)], IP[127.0.0.1], PHP, PasswordField[password], Title[Login :: Damn Vulnerable Web Application (DVWA)]

```

Fig 5: whatweb scan

```

└─$ whatweb -v http://127.0.0.1/DVWA
WhatWeb report for http://127.0.0.1/DVWA
Status      : 301 Moved Permanently
Title       : 301 Moved Permanently
IP          : 127.0.0.1
Country     : RESERVED, ZZ

Summary     : Apache[2.4.68], HTTPServer[Debian Linux][Apache/2.4.68 (Debian)], RedirectLocation[http://127.0.0.1/DVWA/]

Detected Plugins:
[ Apache ]
    The Apache HTTP Server Project is an effort to develop and maintain an open-source HTTP server for modern operating systems including UNIX and Windows NT. The goal of this project is to provide a secure, efficient and extensible server that provides HTTP services in sync with the current HTTP standards.
    Setup / Reset DB
    Version      : 2.4.68 (from HTTP Server Header)
    Google Dorks: (3)
    Website      : http://httpd.apache.org/

[ HTTPServer ]
    Command Injection
    HTTP server header string. This plugin also attempts to identify the operating system from the server header.
    OS           : Debian Linux
    String       : Apache/2.4.68 (Debian) (from server string)
    File Inclusion
    File Upload

[ RedirectLocation ]
    HTTP Server string location. used with http-status 301 and 302
    String       : http://127.0.0.1/DVWA/ (from location)
    SQL Injection
    SQL Injection (Blind)

HTTP Headers:
    HTTP/1.1 301 Moved Permanently
    Date: Thu, 18 Jun 2026 18:04:54 GMT
    Server: Apache/2.4.68 (Debian) (DOM)
    Location: http://127.0.0.1/DVWA/
    Session IDs

```

Fig 6: verbose scan

```
(kali㉿kali)-[~]  
$ curl -I http://127.0.0.1/DVWA  
HTTP/1.1 301 Moved Permanently  
Date: Thu, 18 Jun 2026 18:08:13 GMT  
Server: Apache/2.4.68 (Debian)  
Location: http://127.0.0.1/DVWA/  
Content-Type: text/html; charset=iso-8859-1
```

Fig 7: curl headers

3. DIRECTORY STRUCTURE

Path	Status	Sensitivity	Notes
/DVWA/	200	-	Root application
/config/	301	Critical	Database credentials exposed
/phpinfo.php	302	High	Full server config disclosure
/setup.php	200	High	Database reset accessible
/docs/	301	Medium	Documentation
/vulnerabilities/	301	Medium	Vulnerable scripts
robots.txt	200	Low	Lists disallowed directories

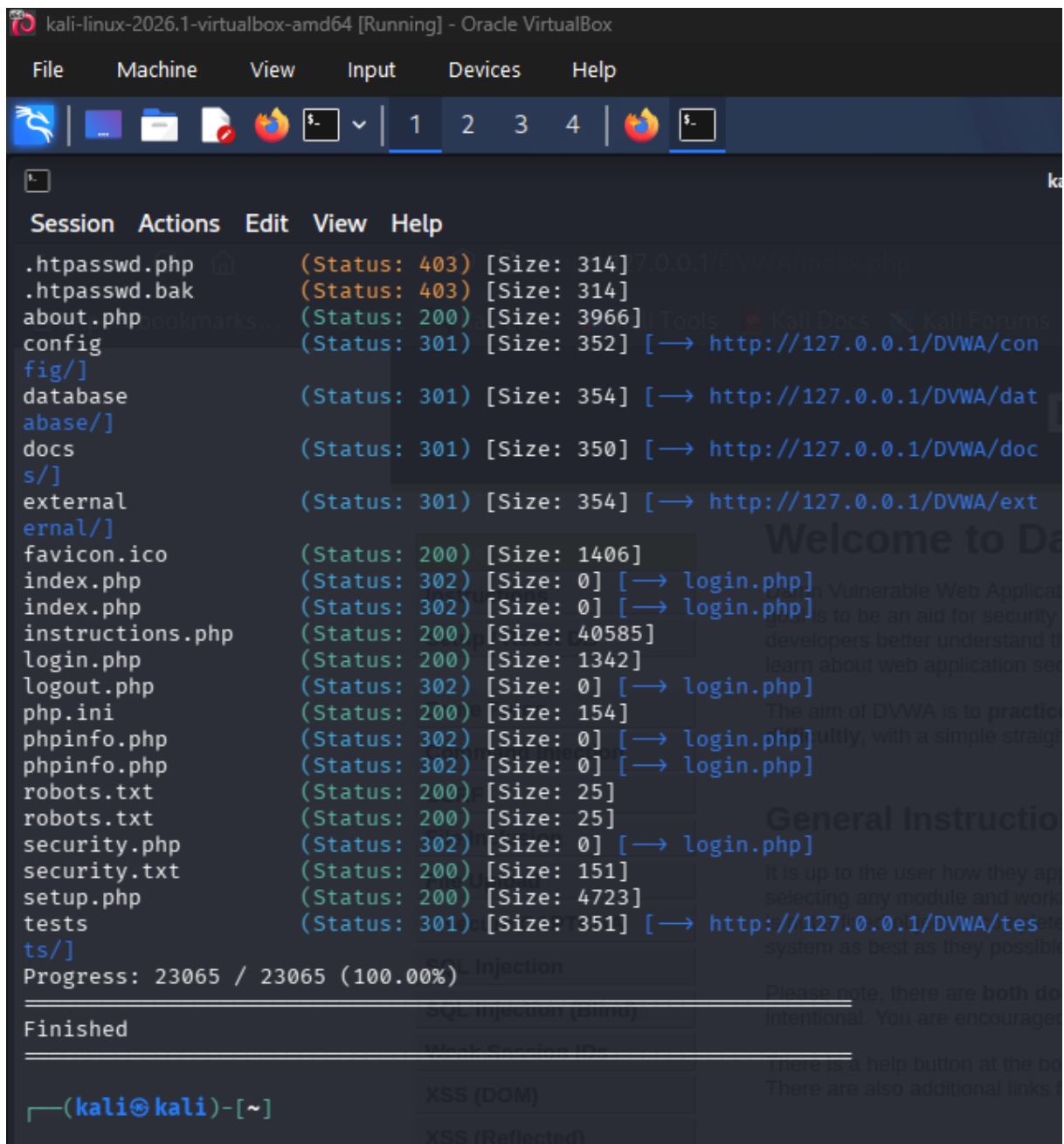


Fig 8: gobuster output

```
(kali㉿kali)-[~]
└─$ curl -s http://127.0.0.1/DVWA/robots.txt
User-agent: *
Disallow: /

(kali㉿kali)-[~]
└─$ curl -s http://127.0.0.1/DVWA/sitemap.xml
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/s
trict.dtd">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.68 (Debian) Server at 127.0.0.1 Port 80</address>
</body></html>

(kali㉿kali)-[~]
└─$
```

Fig 9: robots.txt

4. PARAMETERS IDENTIFIED

Endpoint	Parameter	Potential Vulnerability
/sql/	id	SQL Injection
/brute/	username, password	Brute Force
/exec/	ip	Command Injection
/fi/	page	File Inclusion (LFI/RFI)
/xss_r/	name	Reflected XSS
/login.php	username, password	Authentication

kali@kali: ~

Session Actions Edit View Help

(kali@kali)-[~]
\$ ffuf -u "http://127.0.0.1/DVWA/vulnerabilities/sqli/?FUZZ=1" -w /usr/share/wordlists/dirb/common.txt -H "Cookie: PHPSESSID=b01fc7f8f39d9b8f927b77d27a49c4ff; security=low" -c -t 50

v2.1.0-dev

Vulnerability: SQL

Method	URL	Wordlist	Header	Follow redirects	Calibration	Timeout	Threads	Matcher
GET	http://127.0.0.1/DVWA/vulnerabilities/sqli/?FUZZ=1	/usr/share/wordlists/dirb/common.txt	Cookie: PHPSESSID=b01fc7f8f39d9b8f927b77d27a49c4ff; security=low	false	false	10	50	Response status: 200-299,301,302,307,401,403,405,500

ID: 1
First name: admin
Surname: admin

CSRF

Path	Status	Size	Words	Lines	Duration
.web	302	0	1	1	10ms
.swf	302	0	1	1	4ms
.subversion	302	0	1	1	4ms
.svn/entries	302	0	1	1	4ms
_derived	302	0	1	1	6ms
.profile	302	0	1	1	6ms
_dev	302	0	1	1	11ms
.ssh	302	0	1	1	4ms
.svn	302	0	1	1	6ms
.perf	302	0	1	1	9ms
_img	302	0	1	1	3ms
_flash	302	0	1	1	4ms
_files	302	0	1	1	6ms
_fpclass	302	0	1	1	6ms
_images	302	0	1	1	6ms

XSS (Reflected)

Fig 10: ffuf sqli

id [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 10ms]

kali@kali: ~

Session Actions Edit View Help

(kali@kali)-[~]
\$ ffuf -u "http://127.0.0.1/DVWA/vulnerabilities/brute/?FUZZ=test" -w /usr/share/wordlists/dirb/common.txt -H "Cookie: PHPSESSID=b01fc7f8f39d9b8f927b77d27a49c4ff; security=low" -c -t 5

v2.1.0-dev Home

Vulnerability: SQL Injection

Instructions

Method : GET
URL : http://127.0.0.1/DVWA/vulnerabilities/brute/?FUZZ=test
Wordlist : FUZZ: /usr/share/wordlists/dirb/common.txt
Header : Cookie: PHPSESSID=b01fc7f8f39d9b8f927b77d27a49c4ff; security=low
Follow redirects : false
Calibration : false
Timeout : 10
Threads : 50
Matcher : Response status: 200-299,301,302,307,401,403,405,500

Brute Force

Command Injection

CSRF

More Information

git/HEAD [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 7ms]
.history [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 11ms]
.listings [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 15ms]
.listing [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 15ms]
.htaccess [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 12ms]
.htpasswd [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 12ms]
.passwd [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 21ms]
.mysql_history [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 16ms]
.sh_history [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 6ms]
.bash_history [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 18ms]
.cache [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 17ms]
.cvsignore [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 24ms]
.forward [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 21ms]
.config [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 18ms]

Media.org/wiki/SQL_injection
vulnerability.com/blog
www-common.com/tables.com/

Fig 11: ffuf brute

id [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 10ms]

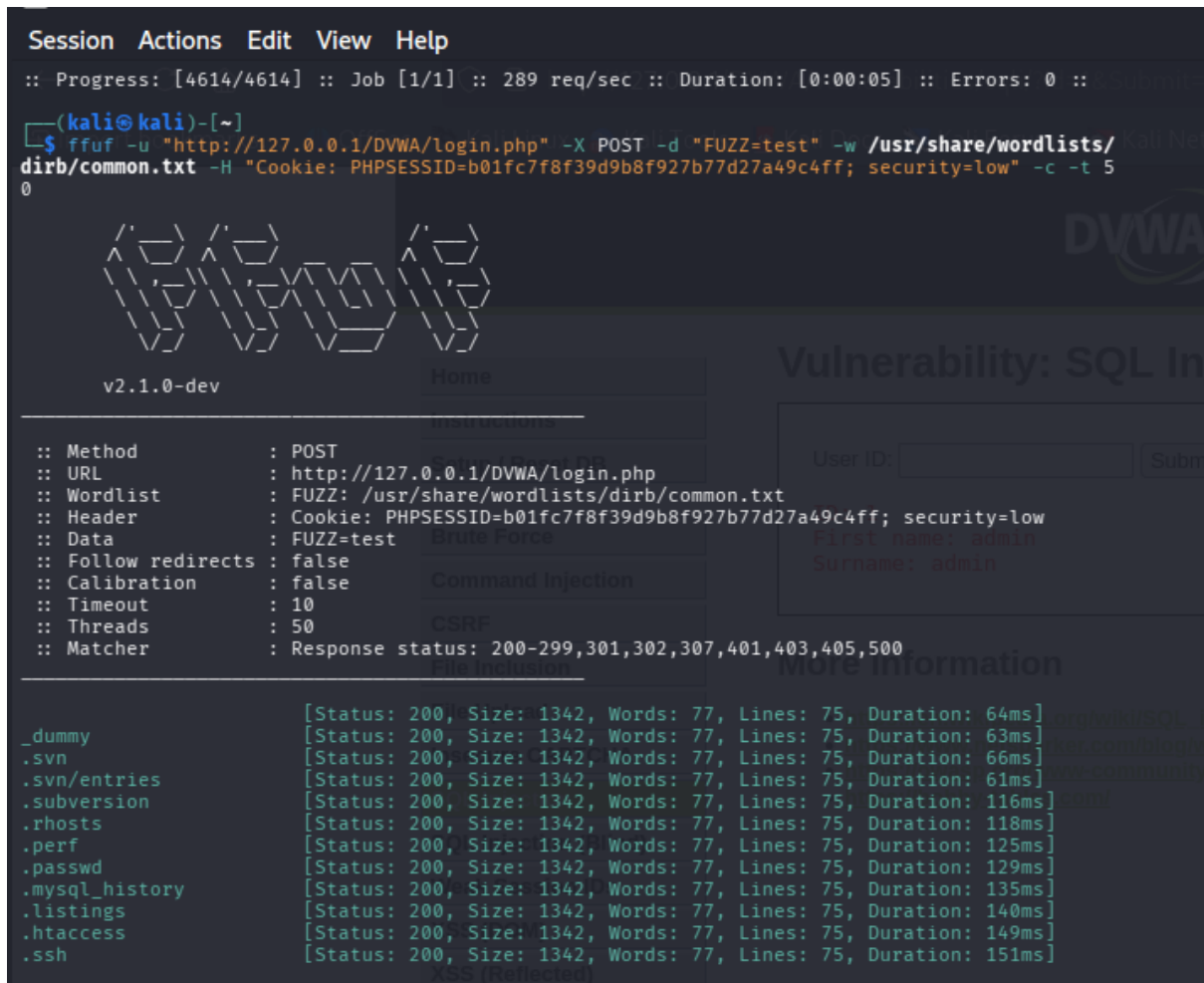


Fig 12: ffuf login

password	[Status: 200, Size: 1342, Words: 77, Lines: 75, Duration: 709ms]
passwor	[Status: 200, Size: 1342, Words: 77, Lines: 75, Duration: 713ms]
username	[Status: 200, Size: 1342, Words: 77, Lines: 75, Duration: 381ms]
usernames	[Status: 200, Size: 1342, Words: 77, Lines: 75, Duration: 383ms]

5. ATTACK SURFACE SUMMARY

Authentication: Login page, brute force endpoint.

Injection Points: SQLi, Command Injection, Reflected XSS.

File Operations: File inclusion, potential LFI/RFI.

Information Disclosure: Server/OS version headers, /config/ directory, /docs/ version info.

Access Control Gaps: setup.php (database reset) publicly reachable without authentication.

6. RECOMMENDATIONS

1. Remove **setup.php** immediately after installation.
2. Restrict access to /config/ directory via .htaccess or move outside.

3. **Remove phpinfo.php** from production.
4. **Do not list sensitive paths** in robots.txt
5. **Implement input validation** and parameterized queries to remediate the SQL Injection, Command Injection, and XSS findings identified at the parameter-discovery stage.